DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

ATLAS

Informe de seguridad y calidad en el desarrollo de software

Sistema de gestión de clientes y contratos

Evaluación Parcial N°3 – Verificando la calidad, seguridad y cumplimiento normativo

ISY1102 - Seguridad y calidad en el desarrollo de software
Sección 003V
Carrera: Ingeniería en Informática
Docente: Cristian Eduardo Medina Cespedes
Fecha: 29 de octubre de 2026

Integrantes
Victor Silva
Jonathan Guerra
Darlette Morales

INDICE

INDICE 2
1. Introducción 4
1.1 Contexto del sistema 4
1.2 Propósito y alcance 4
1.3 Objetivos 4
1.4 Ajustes respecto de la primera evaluación 5
2. Criterios de calidad 5
2.1 Importancia de la calidad, la seguridad y el cumplimiento legal 5
2.2 Criterios de calidad del producto 5
2.3 Criterios de seguridad 6
2.4 Normativa y estándares aplicables 6
3. Plan de pruebas 7
3.1 Estrategia de pruebas 7
3.2 Tipos de prueba 7
3.3 Criterios de aceptación 8
3.4 Herramientas utilizadas 9
3.5 Recursos y entorno de prueba 9
3.6 Cronograma 10
4. Diseño de casos de prueba 10
4.1 Casos de prueba priorizados 10
4.2 Análisis de cobertura, pertinencia y coherencia del plan 17
5. Ejecución de pruebas 19
5.1 Resumen de ejecución 19
5.2 Detalle de ejecución de casos 19
5.3 Criticidad de incidentes 20
5.4 Análisis estático del código 21
6. Análisis ético y normativo de los resultados 23
6.1 Resultados frente a la normativa 23
6.2 Análisis ético 23
6.3 Recomendaciones 24
6.4 Conclusión 24
Anexo A. Matriz de trazabilidad requerimiento–caso 25
Anexo B. Evidencia del análisis estático con SonarQube 26

ÍNDICE DE TABLAS

Tabla 1. Objetivos del plan de pruebas....4
Tabla 2. Criterios de calidad del producto....5
Tabla 3. Normativa y estándares aplicables....6
Tabla 4. Clasificación de los tipos de prueba por objetivo, origen e impacto....7
Tabla 5. Herramientas de prueba, fundamento y estado....9
Tabla 6. Cronograma de actividades....10
Tabla 7. Caso de prueba PT-FUNC-001: Flujo completo de contrato con documento adjunto....10
Tabla 8. Caso de prueba PT-FUNC-002: Autenticación y emisión de JWT....11
Tabla 9. Caso de prueba PT-FUNC-008: Listar, filtrar, editar y eliminar clientes....12
Tabla 10. Caso de prueba PT-FUNC-010: Registro de auditoría de acciones críticas....12
Tabla 11. Caso de prueba PT-SEG-001: Hashing de contraseñas y política de contraseñas....13
Tabla 12. Caso de prueba PT-SEG-002: Control de acceso por rol en el backend (RBAC)....13
Tabla 13. Caso de prueba PT-SEG-008: Sesión JWT: expiración, firma y secreto....14
Tabla 14. Caso de prueba PT-SEG-009: Aislamiento entre empresas y acceso sin autenticación (IDOR)....15
Tabla 15. Caso de prueba PT-PERF-001: Tiempo de respuesta de operaciones CRUD....15
Tabla 16. Caso de prueba PT-USAB-001: Accesibilidad para adultos mayores (WCAG 2.1 AA)....16
Tabla 17. Cobertura de diseño por categoría de requerimientos....17
Tabla 18. Cobertura frente a ISO/IEC 25010, OWASP Top 10 y WCAG....18
Tabla 19. Pertinencia: riesgos, evidencia y pruebas asignadas....18
Tabla 20. Resumen de ejecución....19
Tabla 21. Detalle de ejecución por caso (29 de octubre de 2026, Docker local)....19
Tabla 22. Escala de criticidad de incidentes....20
Tabla 23. Incidentes identificados y su criticidad....20
Tabla 24. Resultados del análisis estático....21
Tabla 25. Hallazgos de la revisión estática manual contrastados con la ejecución....22
Tabla 26. Resultados frente a la normativa....23
Tabla 27. Recomendaciones vinculadas a la evidencia....24
Tabla 28. Matriz de trazabilidad requerimiento–caso....25
Tabla 29. Ficha del análisis con SonarQube....26
Tabla 30. Vulnerabilidades detectadas por SonarQube....26

1. Introducción

1.1 Contexto del sistema

Atlas es una plataforma web de gestión de clientes y contratos para pequeñas y medianas empresas (pymes) chilenas. Permite registrar empresas, administrar usuarios con roles (administrador y editor), gestionar clientes y contratos, adjuntar un documento a cada contrato y auditar las acciones críticas. Se compone de un frontend React, un backend Node.js/Express y una base de datos PostgreSQL, desplegados con Docker Compose (frontend en el puerto 3350 y API en el 4450). Su Especificación de Requerimientos de Software (ERS v1.1) define **42 requerimientos**: 17 funcionales (RF), 20 no funcionales (NFR) y 5 reglas de negocio (RB).

Atlas maneja datos sensibles de terceros (RUT, direcciones, correos, teléfonos, datos bancarios y documentos contractuales). Un defecto puede comprometer la privacidad de los clientes finales de cada pyme y el cumplimiento de la normativa chilena.

1.2 Propósito y alcance

El plan de pruebas busca asegurar que Atlas **cumple el ERS** (calidad), **protege los datos y los accesos** (seguridad) y **respeta el marco legal y ético aplicable** (cumplimiento normativo).

Dentro del alcance: 16 de los 42 requerimientos del ERS (más el criterio de aceptación de interfaz §3.1.1), elegidos por riesgo (probabilidad × impacto) y verificados con 10 casos de prueba funcionales, de seguridad, de rendimiento y de usabilidad, además del análisis estático del código y la verificación técnica del cumplimiento de las leyes 19.628 y 20.422. El ERS no se modificó: los demás requerimientos quedan **fuera del alcance de este ciclo**. **Fuera del alcance:** compatibilidad, disponibilidad, TLS, cifrado en reposo y la mayor parte de usabilidad (riesgo residual declarado), pruebas unitarias (el código no las incluye y el ERS no las exige), auditoría legal formal, escalabilidad horizontal y despliegue en producción.

1.3 Objetivos

Tabla 1. Objetivos del plan de pruebas

N.º	Objetivo	Indicador de logro	Requerimiento / norma
O1	Verificar las funciones y reglas de negocio del ERS.	Resultado verificado y con evidencia para cada RF y RB del alcance.	RF-1 a 6; RB-1 a 5
O2	Verificar los controles de seguridad.	0 escrituras con rol editor; contraseñas con bcrypt; 0 alertas altas en ZAP.	NFR-SEG-1 a 9; Ley 19.628
O3	Medir el rendimiento frente a los umbrales del ERS.	p95 < 300 ms en CRUD simples; error 5xx < 1 %.	NFR-PERF-1 a 3
O4	Evaluar usabilidad y accesibilidad.	Lighthouse ≥ 90 y 0 incidencias críticas en axe.	NFR-USAB-1; Ley 20.422

N.º	Objetivo	Indicador de logro	Requerimiento / norma
O5	Asegurar trazabilidad y cobertura.	Cobertura de diseño del alcance: 100 %; cobertura frente al ERS completo informada.	Anexo A
O6	Clasificar los defectos y analizar su impacto ético y normativo.	Cada incidente con ID, caso, requerimiento, evidencia, criticidad y norma.	Secciones 5 y 6

1.4 Ajustes respecto de la primera evaluación

Se incorporó la retroalimentación del docente a EP1: el índice quedó definido (índice general e índice de tablas); la cobertura se midió sobre los 42 requerimientos reales del ERS (en EP1 se contaban 6) y se separó cobertura de diseño y de ejecución (sección 4.2); y los casos usan las rutas reales del backend y se priorizan por riesgo.

2. Criterios de calidad

2.1 Importancia de la calidad, la seguridad y el cumplimiento legal

Calidad. El ERS fija 300 ms para operaciones CRUD simples, pero la ejecución midió un p95 de 4,0 s en el login y en el listado de clientes por un retardo artificial en el código: cada ingreso de una pyme es lento y se incumple un requisito medible. El análisis estático detectó además 25 bugs de confiabilidad, como promesas sin manejo de errores en la interfaz.

Seguridad. En la ejecución, el token de sesión no incluye el rol y un usuario editor pudo crear, modificar y eliminar datos e incluso crear un usuario administrador, aunque el ERS indica que solo puede leer (RB-4). Las consecuencias recaen en los clientes finales de las pymes, que nunca interactúan con el sistema.

Cumplimiento legal. Atlas almacena datos personales y bancarios: el artículo 11 de la Ley 19.628 obliga a quien administra el banco de datos a cuidarlos, y la Ley 20.422 y WCAG 2.1 AA orientan la accesibilidad para adultos mayores. Los tres aspectos se verifican a la vez y cada resultado se vincula a un requerimiento y a una norma.

2.2 Criterios de calidad del producto

Tabla 2. Criterios de calidad del producto

Característica	Criterio de calidad (medible)	Requerimiento
Usabilidad y accesibilidad	Tipografía legible, contraste ≥ 4,5:1 y controles grandes para adultos mayores; flujos de registro, creación de empresa y cliente → contratos claros; ayuda contextual y mensajes de error amigables.	NFR-USAB-1 a 4
Rendimiento	CRUD simples < 300 ms (p95); página principal < 2 s en conexión móvil; 200 usuarios concurrentes; subida y descarga de documentos ≤ 10 s.	NFR-PERF-1 a 3; criterio RF-5

Característica	Criterio de calidad (medible)	Requerimiento
Estabilidad y confiabilidad	Disponibilidad objetivo 99,5 % mensual; recuperación tras caída y datos persistentes tras reinicio.	NFR-DIS-1
Mantenibilidad	Ventana de mantenimiento y migración segura; sin defectos de alta severidad según análisis estático.	NFR-DIS-2
Compatibilidad	Funcionamiento idéntico en las últimas 2 versiones de Chrome, Firefox, Safari y Edge; diseño responsivo.	NFR-COMPAT-1, 2
Adecuación funcional	Autenticación, usuarios y roles, clientes, contratos con documento y auditoría operan según el ERS.	RF-1 a 6; RB-1 a 5

2.3 Criterios de seguridad

- **Protección de datos:** contraseñas con hash bcrypt (NFR-SEG-2), TLS (NFR-SEG-1), cifrado de datos sensibles en reposo (NFR-SEG-3) y cumplimiento de protección de datos personales (NFR-SEG-8).
- **Control de acceso:** autorización por rol validada en el backend (NFR-SEG-4; RB-4 y RB-5), aislamiento entre empresas (RB-2) y sesión JWT con expiración (NFR-SEG-9).
- **Manejo de errores:** respuestas genéricas al usuario y detalle solo en logs internos, sin secretos (NFR-SEG-6).
- **Integridad:** validación de entradas contra inyección SQL, XSS y CSRF (NFR-SEG-5), auditoría de acciones críticas (RF-6.1) y respaldo y recuperación (NFR-SEG-7).

2.4 Normativa y estándares aplicables

Tabla 3. Normativa y estándares aplicables

Norma / estándar	Aplicación a Atlas	Vínculo con el ERS
Ley 19.628 (vida privada)	Atlas almacena datos personales y bancarios; el art. 11 exige deber de cuidado del responsable del banco de datos.	NFR-SEG-1, 2, 3, 8
Ley 21.719 (datos personales)	Publicada en diciembre de 2024 con vigencia diferida (a confirmar: 1 de diciembre de 2026). Se usa como referencia de buenas prácticas.	NFR-SEG-8
Ley 20.422 y WCAG 2.1 AA	Accesibilidad para personas con discapacidad y adultos mayores: contraste, teclado, etiquetas.	NFR-USAB-1
ISO/IEC 25010	Modelo de calidad que estructura los criterios de la sección 2.2.	NFR-PERF, USAB, DIS, COMPAT
OWASP Top 10 (2021) y Testing Guide	Clasificación de vulnerabilidades y metodología de pruebas de seguridad.	NFR-SEG-4, 5, 6, 9
Ley 21.459 (delitos informáticos)	Límite ético: las pruebas intrusivas se hacen solo en el entorno Docker entregado, con datos ficticios.	Marco de ejecución

3. Plan de pruebas

3.1 Estrategia de pruebas

Enfoque **mixto y basado en riesgo**: se automatiza lo repetible y medible (API, carga, escaneo de código y de la aplicación) y se ejecuta manualmente lo que exige juicio humano (revisión de código e interpretación de los resultados de las herramientas). La seguridad tiene prioridad porque Atlas maneja datos personales.

- **Enfoque:** SAST (análisis estático), DAST (aplicación en ejecución) y pruebas de caja negra basadas en el ERS, ejecutadas con scripts reproducibles.
- **Etapas:** preparación del entorno y datos ficticios; análisis estático; pruebas funcionales vía API; seguridad de autenticación y autorización; seguridad dinámica; rendimiento; accesibilidad; consolidación de incidentes y matriz.
- **Priorización:** P1 seguridad (autenticación, autorización, datos) y funciones núcleo (login, clientes, contratos); P2 rendimiento, accesibilidad y trazabilidad (auditoría); compatibilidad y disponibilidad quedan fuera del alcance de este ciclo (sección 1.2).
- **Criterios de entrada:** código versionado, stack Docker operativo, datos de prueba ficticios cargados y casos revisados.
- **Criterios de salida:** casos P1 y P2 ejecutados con evidencia, informando la cobertura de ejecución real; incidentes clasificados y trazados a su caso y requerimiento; matriz actualizada.
- **Regresión:** la re-ejecución de los casos fallidos se diseña para después de corregir el código; no se ejecuta en este ciclo porque la corrección del sistema no forma parte del alcance.

3.2 Tipos de prueba

Los tipos se clasifican por objetivo en **funcionales**, **no funcionales** (rendimiento, usabilidad, compatibilidad, disponibilidad) y de **seguridad**. Se indica su propósito, origen, impacto si falla y casos asociados.

Tabla 4. Clasificación de los tipos de prueba por objetivo, origen e impacto

Tipo	Propósito y aplicación en Atlas	Origen	Impacto si falla	Casos	Ejecución
Funcionales (caja negra, API y E2E)	Comprobar que cada función cumple lo especificado, sobre los endpoints REST y los flujos de login, clientes, contratos con documento y auditoría.	RF-1 a 6; RB-1 a 5	Datos corruptos o procesos de negocio rotos.	PT-FUNC-001, 002, 008, 010	Ejecutado: 4 de 4
Integración	Verificar la comunicación entre frontend, API, base de datos y almacenamiento de documentos.	Arquitectura del ERS	Flujos completos rotos aunque cada módulo funcione.	PT-FUNC-001	Ejecutado

Tipo	Propósito y aplicación en Atlas	Origen	Impacto si falla	Casos	Ejecución
Seguridad estática (SAST)	Detectar vulnerabilidades leyendo el código sin ejecutarlo (SonarQube, Semgrep, Gitleaks, Trivy).	NFR-SEG; OWASP	Defectos de diseño que otras pruebas no ven (credenciales en el código).	Transversal	Ejecutado: SonarQube, Trivy, Gitleaks, Semgrep
Seguridad dinámica y de autorización (DAST)	Atacar la aplicación en ejecución: control de acceso por rol, aislamiento entre empresas y sesión JWT; ZAP baseline revisa cabeceras y CORS.	NFR-SEG-4, 5, 9; RB-2, 4	Acceso no autorizado a datos de otra empresa o suplantación de usuarios.	PT-SEG-002, 008, 009; ZAP	Ejecutado: 3 de 3
Seguridad de datos y normativa	Verificar el hash de contraseñas y el cumplimiento técnico de la Ley 19.628.	NFR-SEG-2, 8	Fuga de credenciales y datos personales; responsabilidad legal.	PT-SEG-001	Ejecutado: 1 de 1
Rendimiento (carga)	Medir tiempos de respuesta de las operaciones CRUD con k6.	NFR-PERF-1	Sistema lento en el uso diario.	PT-PERF-001	Ejecutado
Usabilidad y accesibilidad	Evaluar si los adultos mayores pueden operar el sistema (WCAG 2.1 AA).	NFR-USAB-1; Ley 20.422	Exclusión de usuarios y errores de operación.	PT-USAB-001	Ejecutado con herramientas (sin usuarios reales)
Compatibilidad	Verificar navegadores y dispositivos definidos.	NFR-COMPAT-1, 2	Funciones inutilizables en ciertos entornos.	Sin caso priorizado	No incluida (riesgo residual)
Disponibilidad y recuperación	Comprobar reinicio ante caída, persistencia y respaldo restaurable.	NFR-DIS-1, 2; NFR-SEG-7	Indisponibilidad prolongada o pérdida de datos.	Sin caso priorizado	No incluida (riesgo residual)
Regresión	Re-ejecutar los casos fallidos tras corregir el código.	ISO/IEC/ IEEE 29119	Reaparición de defectos corregidos.	—	Diseñada; se ejecuta tras corregir el código
Aceptación	Validación con usuarios clave del negocio.	ERS §3.1.1	Sistema que cumple la especificación pero no la necesidad.	PT-USAB-001 (parcial)	Fuera de alcance salvo la parte con usuarios

Por técnica, las pruebas funcionales, DAST, de rendimiento y de usabilidad son de **caja negra** (parten del ERS) y el análisis estático y la revisión de código son de **caja blanca**. Son **automatizadas** el cliente HTTP en Python, k6, ZAP, Lighthouse y SonarQube, y **manuales** la revisión de código y la inspección de la base de datos. Por nivel, se aplican pruebas de integración y de sistema; las unitarias no se aplican porque el código no las incluye (riesgo residual declarado en la sección 4.2).

3.3 Criterios de aceptación

Un caso se aprueba solo si cumple todos sus criterios con evidencia (captura o log). Los criterios transversales son:

- **Funcional:** el resultado coincide con el ERS (códigos HTTP, datos persistidos, registros de auditoría); el resultado esperado se deriva del ERS, no del comportamiento actual del código.
- **No funcional:** p95 < 300 ms en CRUD simples; página principal < 2 s; error 5xx < 1 %; Lighthouse de accesibilidad ≥ 90 con 0 incidencias críticas o serias en axe.

- **Seguridad:** 0 escrituras exitosas con rol editor; contraseñas con bcrypt (costo ≥ 10); 0 alertas de riesgo alto en ZAP; errores sin detalles internos.
- **Reglas de negocio:** un contrato pertenece a un único cliente (RB-3); solo usuarios con relación en empresa_usuarios acceden a datos de la empresa (RB-2); el editor solo lee (RB-4).

3.4 Herramientas utilizadas

Tabla 5. Herramientas de prueba, fundamento y estado

Herramienta	Fundamento de uso	Tipo de prueba	Estado
SonarQube Community 26.10	SAST principal: vulnerabilidades, bugs y code smells en backend y frontend, con severidad independiente de la revisión manual.	Seguridad / mantenibilidad	Ejecutada
Semgrep, Gitleaks y Trivy	Complementan a SonarQube: Semgrep aplica reglas de JavaScript y OWASP Top 10; Gitleaks busca secretos; Trivy revisa dependencias, Dockerfiles y la imagen del backend.	Seguridad (SAST / SCA)	Ejecutadas
OWASP ZAP (baseline)	DAST pasivo: cabeceras, CORS y configuración del frontend y la API en ejecución.	Seguridad (DAST)	Ejecutada
Cliente HTTP en Python (curl / OpenAPI)	Pruebas de API reproducibles sobre openapi.json, equivalentes a una colección Newman (§3.1.2 del ERS), con evidencia por caso.	Funcional / seguridad	Ejecutado
k6	Pruebas de carga con umbrales (p95 < 300 ms, errores < 1 %) y con 200 usuarios concurrentes.	Rendimiento	Ejecutada
Lighthouse y axe-core	Auditoría automatizada de accesibilidad y carga de las pantallas principales.	Usabilidad / rendimiento	Ejecutadas
Docker y Docker Compose	Entorno reproducible y aislado entregado por la asignatura.	Todas	En uso

3.5 Recursos y entorno de prueba

- **Recursos humanos:** tres integrantes (Victor Silva, Jonathan Guerra y Darlette Morales) que comparten los roles de coordinación, ejecución funcional/API y seguridad/rendimiento.
- **Recursos técnicos:** equipo Linux con Docker, Chrome y las herramientas de la sección 3.4. Limitación: no se reunieron adultos mayores, por lo que la usabilidad se mide solo con herramientas automáticas.
- **Entorno:** stack Docker Compose de Atlas (frontend http://localhost:3350, API http://localhost:4450, Swagger en /docs, PostgreSQL en atlas-postgres), con usuarios semilla admin y editor y datos ficticios.

3.6 Cronograma

Tabla 6. Cronograma de actividades

N.º	Actividad	Estado	Momento
1	Análisis del ERS, matriz de trazabilidad y diseño de los 10 casos priorizados.	Completada	Antes de la ejecución
2	Revisión estática manual del código (19 hallazgos con archivo y línea).	Completada	Antes de la ejecución
3	Análisis estático con SonarQube, Trivy y Gitleaks en Docker.	Completada (29-oct-2026)	Ejecución
4	Ejecución de los casos funcionales y de seguridad sobre el stack Docker de Atlas.	Completada (29-oct-2026)	Ejecución
5	Ejecución de los casos de rendimiento y usabilidad.	Completada (29-oct-2026)	Ejecución
6	Consolidación de incidentes, matriz de trazabilidad y elaboración del informe.	Completada	Después de la ejecución
7	Re-ejecución de los casos fallidos (regresión) tras corregir el código.	Pendiente (posterior a esta entrega)	Futuro

4. Diseño de casos de prueba

4.1 Casos de prueba priorizados

Se priorizaron **10 casos** por riesgo (probabilidad × impacto): cuatro funcionales (PT-FUNC-001, 002, 008 y 010), cuatro de seguridad (PT-SEG-001, 002, 008 y 009), uno de rendimiento (PT-PERF-001) y uno de usabilidad (PT-USAB-001). Verifican las funciones núcleo del negocio y los controles de seguridad de mayor impacto sobre los datos personales; el alcance de requerimientos, la cobertura y las brechas se analizan en la sección 4.2 y el Anexo A. Los resultados esperados se derivan del ERS y los datos son ficticios. En los comandos, $API equivale a http://localhost:4450.

Tabla 7. Caso de prueba PT-FUNC-001: Flujo completo de contrato con documento adjunto

ID	NOMBRE	REQUERIMIENTO
PT-FUNC-001	Flujo completo de contrato con documento adjunto	RF-5.1, RF-5.2, RF-5.3, RB-3 (apoyo: RF-6.1)
DESCRIPCIÓN		
Verificar que un administrador crea un cliente y un contrato asociado a un único cliente, adjunta un documento en formato permitido, lo recupera íntegro, que la acción queda auditada y que los formatos o tamaños no permitidos son rechazados.		
PRECONDICIONES		
Stack Atlas levantado con docker compose; token de administrador obtenido en POST /autenticacion/login; base de datos con datos semilla; archivos de prueba disponibles.		
PASOS		
1. POST /clientes con el token de administrador y registrar el cliente_id. 2. POST /contratos (multipart) con los datos del contrato y el archivo contrato.pdf; registrar el contrato_id. 3. GET /contratos/{id}/file y comparar el hash sha256 con el del archivo original. 4. POST /contratos con macro.exe y, por separado, con grande.pdf. 5. Consultar la tabla documentos_contrato para verificar cómo se almacena el documento. 6. GET /auditoria y buscar el registro de la creación del contrato. 7. POST /contratos con un cliente_id inexistente.		

RESULTADO ESPERADO
Paso 2: HTTP 201 y contrato asociado a un único cliente (RB-3). Paso 3: el archivo descargado es idéntico al subido (mismo hash). Paso 4: macro.exe rechazado con 4xx (el ERS admite solo PDF, DOC, PPT, JPG y PNG); el archivo excesivo rechazado con 400 o 413. Paso 5: el documento queda en el almacenamiento interno y la base de datos guarda solo la referencia (RF-5.3). Paso 6: existe un registro de auditoría de la creación y de la subida. Paso 7: error 4xx con mensaje controlado y sin contrato huérfano.
CRITERIO DE ACEPTACIÓN
☐ Contrato creado con respuesta 201 y asociado a un solo cliente. ☐ Hash del archivo recuperado igual al del original. ☐ Solo se aceptan los 5 formatos del ERS; .exe devuelve 4xx. ☐ Existe y se aplica un límite de tamaño de archivo. ☐ Subida y descarga completadas en ≤ 10 s. ☐ Registro de auditoría presente por cada acción crítica.
DATOS DE PRUEBA
Cliente: nombre = "Cliente Prueba SpA", correo = "prueba@atlasfake.com". Contrato: título = "Servicios 2026", descripción = "Contrato de prueba", fecha_inicio = 2026-01-01, fecha_fin = 2026-12-31. Archivos: contrato.pdf (< 1 MB), foto.png, macro.exe (no permitido), grande.pdf (≈ 30 MB).
TIPO DE PRUEBA
Funcional – extremo a extremo (API + base de datos)

Tabla 8. Caso de prueba PT-FUNC-002: Autenticación y emisión de JWT

ID	NOMBRE	REQUERIMIENTO
PT-FUNC-002	Autenticación y emisión de JWT	RF-1.1
DESCRIPCIÓN		
Verificar que un usuario registrado inicia sesión con su nombre de usuario y contraseña, que recibe un JWT con expiración y que las credenciales inválidas son rechazadas.		
PRECONDICIONES		
Stack levantado; usuarios semilla admin y editor existentes.		
PASOS		
1. POST /autenticacion/login con admin/admin y decodificar el payload del JWT. 2. POST /autenticacion/login con una contraseña incorrecta. 3. POST /autenticacion/login con un usuario inexistente. 4. POST /autenticacion/login con el cuerpo vacío.		
RESULTADO ESPERADO		
Paso 1: HTTP 200 y un JWT con expiración (exp). Pasos 2 a 4: HTTP 401 con un mensaje genérico, sin indicar si el usuario existe.		
CRITERIO DE ACEPTACIÓN		
☐ El login válido responde 200 con un JWT. ☐ El JWT incluye expiración (exp). ☐ El 100 % de las credenciales inválidas se rechaza con 401.		
DATOS DE PRUEBA		
Credenciales válidas: admin/admin (usuario semilla ficticio). Credenciales inválidas: contraseña incorrecta, usuario inexistente y cuerpo vacío.		
TIPO DE PRUEBA		
Funcional – API		

Tabla 9. Caso de prueba PT-FUNC-008: Listar, filtrar, editar y eliminar clientes

ID	NOMBRE	REQUERIMIENTO
PT-FUNC-008	Listar, filtrar, editar y eliminar clientes	RF-4.2
DESCRIPCIÓN		
Verificar que el administrador lista los clientes con paginación, los filtra por nombre, los edita y los elimina de forma lógica, conservando el registro para la trazabilidad.		
PRECONDICIONES		
Stack levantado; token de administrador; al menos tres clientes de prueba.		
PASOS		
1. GET /clientes?page=1&limit=2. 2. GET /clientes/search?name=<texto> con parte del nombre de un cliente. 3. PUT /clientes/{id} cambiando el nombre. 4. DELETE /clientes/{id} y consultar la tabla clientes por ese id.		
RESULTADO ESPERADO		
Paso 1: devuelve como máximo 2 elementos. Paso 2: devuelve el cliente buscado. Paso 3: HTTP 200 con el dato actualizado. Paso 4: el registro permanece en la base de datos con una marca de baja (eliminación lógica).		
CRITERIO DE ACEPTACIÓN		
☐ El listado admite paginación (limit=2 devuelve ≤ 2 elementos). ☐ El filtro por nombre devuelve el cliente buscado. ☐ La edición responde 200. ☐ Eliminación lógica: el registro sigue en la BD con marca de baja.		
DATOS DE PRUEBA		
Clientes ficticios "Lista n" con correo @atlasfake.com. Búsqueda por un fragmento del nombre.		
TIPO DE PRUEBA		
Funcional – API + base de datos		

Tabla 10. Caso de prueba PT-FUNC-010: Registro de auditoría de acciones críticas

ID	NOMBRE	REQUERIMIENTO
PT-FUNC-010	Registro de auditoría de acciones críticas	RF-6.1 (apoyo: RB-2)
DESCRIPCIÓN		
Verificar que las acciones críticas (crear, editar y eliminar clientes y contratos; subir y descargar documentos) quedan registradas con su usuario y detalle, y que la auditoría solo puede consultarse con autenticación.		
PRECONDICIONES		
Stack levantado; token de administrador; cliente y contrato de prueba.		
PASOS		
1. Crear y editar un cliente con POST y PUT /clientes. 2. Crear un contrato con documento y eliminarlo con DELETE /contratos/{id}. 3. Descargar el documento con GET /contratos/{id}/file. 4. GET /auditoria con token y buscar un registro por cada acción. 5. GET /auditoria sin token.		
RESULTADO ESPERADO		
Pasos 1 a 3: cada acción crea un registro con su usuario y detalle. Paso 5: HTTP 401; la auditoría no es pública.		
CRITERIO DE ACEPTACIÓN		
☐ Se audita: crear cliente.		

☐ Se audita: editar cliente. ☐ Se audita: crear contrato / subir documento. ☐ Se audita: descargar documento. ☐ Se audita: eliminar contrato. ☐ La auditoría solo es consultable con autenticación.
DATOS DE PRUEBA
Cliente ficticio "Cliente AUD" y un contrato con PDF. Consulta de auditoría con y sin encabezado Authorization.
TIPO DE PRUEBA
Funcional – API + base de datos

Tabla 11**. Caso de prueba PT-SEG-001: Hashing de contraseñas y política de contraseñas**

ID	NOMBRE	REQUERIMIENTO
PT-SEG-001	Hashing de contraseñas y política de contraseñas	NFR-SEG-2; restricción ERS §2.4
DESCRIPCIÓN		
Comprobar que las contraseñas se almacenan con hash bcrypt (con sal y costo adecuado), que el sistema impone la política de contraseñas del ERS y que el inicio de sesión funciona sin exponer el valor almacenado.		
PRECONDICIONES		
Stack levantado; acceso al contenedor atlas-postgres; resultados de SonarQube disponibles; usuarios semilla admin y editor existentes.		
PASOS		
1. SAST: buscar el uso de bcrypt o argon2 en el código del backend y en package.json. 2. docker exec atlas-postgres psql -U postgres -d atlas -c "SELECT nombre_usuario, contrasena_hash FROM usuarios;". 3. Registrar usuarios con POST /usuarios usando las tres contraseñas de prueba. 4. Consultar de nuevo la base de datos para el usuario recién creado. 5. Iniciar sesión con la contraseña correcta y con una incorrecta.		
RESULTADO ESPERADO		
Pasos 1, 2 y 4: dependencia y llamadas de hashing presentes; la columna tiene formato bcrypt ($2a$/$2b$/$2y$) con costo ≥ 10 y ninguna contraseña es legible. Paso 3: "abc" y "Atlas2026Segura" rechazadas por el backend (política: mínimo 12 caracteres con mayúscula, minúscula, número y símbolo); "Atlas#2026-Segura" aceptada. Paso 5: credencial correcta → 200 con token; incorrecta → 401 con mensaje genérico.		
CRITERIO DE ACEPTACIÓN		
☐ 100 % de los registros de usuarios tienen hash bcrypt con costo ≥ 10. ☐ Dos usuarios con la misma contraseña producen hashes distintos (sal). ☐ El backend rechaza las contraseñas que incumplen la política. ☐ Ninguna respuesta ni log contiene la contraseña.		
DATOS DE PRUEBA		
Usuarios existentes: admin, editor. Contraseñas: débil = "abc"; sin símbolo = "Atlas2026Segura"; conforme = "Atlas#2026-Segura". Alta: {"nombre_usuario":"qa_hash","contrasena_hash":"<contraseña>","correo":"qa_hash@atlasfake.com"}.		
TIPO DE PRUEBA		
Seguridad – confidencialidad (SAST + inspección de BD + API)		

Tabla 12**. Caso de prueba PT-SEG-002: Control de acceso por rol en el backend (RBAC)**

ID	NOMBRE	REQUERIMIENTO

PT-SEG-002	Control de acceso por rol en el backend (RBAC)	NFR-SEG-4, RF-3.2, RB-4, RB-5
DESCRIPCIÓN		
Verificar que el backend, y no solo la interfaz, impide que el rol editor cree, modifique o elimine datos, y que el administrador conserva acceso completo.		
PRECONDICIONES		
Stack levantado; tokens de admin (TOKEN_ADMIN) y editor (TOKEN_EDITOR) obtenidos; un cliente C1 y un contrato K1 creados por el administrador.		
PASOS		
1. Decodificar el payload de ambos JWT y comprobar si incluyen el rol. 2. Con TOKEN_EDITOR ejecutar: GET /clientes, POST /clientes, PUT /clientes/{C1}, DELETE /clientes/{C1}, POST /contratos, DELETE /contratos/{K1}, POST /empresa-usuarios y DELETE /usuarios/{id}. 3. Repetir la lista con TOKEN_ADMIN. 4. En el frontend, iniciar sesión como editor, cambiar localStorage.role a "administrador", recargar e intentar crear un cliente.		
RESULTADO ESPERADO		
Editor: GET → 200; todas las operaciones de escritura → 403 con cuerpo genérico. Administrador: lectura y escritura permitidas (2xx). Paso 4: aunque se altere el rol en el navegador, el servidor rechaza la operación. El token contiene el rol y el servidor lo valida (o lo consulta en empresa_usuarios).		
CRITERIO DE ACEPTACIÓN		
☐ 0 operaciones de escritura exitosas con rol editor (de 8 intentos). ☐ 100 % de operaciones permitidas para el administrador. ☐ La decisión de autorización se toma en el servidor. ☐ Las respuestas 403 no revelan detalles internos.		
DATOS DE PRUEBA		
TOKEN_ADMIN (admin/admin) y TOKEN_EDITOR (editor/editor), usuarios semilla ficticios. Cliente C1 y contrato K1 creados por el administrador. Operaciones: GET/POST/PUT/DELETE de clientes, POST/DELETE de contratos, POST /empresa-usuarios, DELETE /usuarios/{id}.		
TIPO DE PRUEBA		
Seguridad – autorización (caja negra por API + inspección del token)		

Tabla 13**. Caso de prueba PT-SEG-008: Sesión JWT: expiración, firma y secreto**

ID	NOMBRE	REQUERIMIENTO
PT-SEG-008	Sesión JWT: expiración, firma y secreto	NFR-SEG-9
DESCRIPCIÓN		
Verificar que la sesión basada en JWT usa un secreto robusto y no público, rechaza los tokens alterados o expirados y limita su tiempo de vida.		
PRECONDICIONES		
Stack levantado con docker compose; acceso al contenedor atlas-backend para leer su variable JWT_SECRET.		
PASOS		
1. docker exec atlas-backend env y leer JWT_SECRET. 2. Firmar un token con el secreto por defecto del docker-compose y llamar a GET /clientes. 3. Enviar un token con la firma alterada. 4. Enviar un token con alg=none. 5. Enviar un token expirado, firmado correctamente. 6. Decodificar un token válido y calcular su tiempo de vida.		
RESULTADO ESPERADO		

Paso 1: secreto robusto, no un valor por defecto publicado. Pasos 2 a 5: HTTP 401 en todos los casos. Paso 6: tiempo de vida ≤ 2 h.
CRITERIO DE ACEPTACIÓN
☐ El secreto JWT es robusto y no es un valor por defecto público. ☐ Un token firmado con el secreto por defecto es rechazado. ☐ Un token con firma alterada es rechazado. ☐ Un token con alg=none es rechazado. ☐ Un token expirado es rechazado. ☐ El tiempo de vida del token es acotado (≤ 2 h).
DATOS DE PRUEBA
Secreto por defecto del docker-compose: your-secret-key-change-in-production. Tokens forjados con datos ficticios del usuario semilla admin.
TIPO DE PRUEBA
Seguridad – autenticación y sesión

Tabla 14**. Caso de prueba PT-SEG-009: Aislamiento entre empresas y acceso sin autenticación (IDOR)**

ID	NOMBRE	REQUERIMIENTO
PT-SEG-009	Aislamiento entre empresas y acceso sin autenticación (IDOR)	RB-2 (apoyo: NFR-SEG-4)
DESCRIPCIÓN		
Verificar que un usuario de una empresa no puede ver ni modificar clientes, contratos, archivos ni auditoría de otra empresa, y que los endpoints de contratos y archivos exigen autenticación.		
PRECONDICIONES		
Stack levantado; empresas A y B con un administrador cada una; cliente y contrato con PDF creados en la empresa A.		
PASOS		
1. Con el token de B: GET y PUT /clientes/{cliente de A}. 2. Con el token de B: GET /contratos/{contrato de A} y GET /contratos/{id}/file. 3. Con el token de B: GET /auditoria y POST /contratos para el cliente de A. 4. Sin token: GET /contratos/{id}, GET /contratos/{id}/file y POST /contratos.		
RESULTADO ESPERADO		
Pasos 1 a 3: HTTP 403 o 404; ninguna lectura ni escritura sobre datos de A, y la auditoría solo muestra acciones de B. Paso 4: HTTP 401 en las tres peticiones.		
CRITERIO DE ACEPTACIÓN		
☐ 0 recursos de otra empresa accesibles o modificables, con token de otra empresa o sin token (de 9 intentos).		
DATOS DE PRUEBA		
Empresa A: cliente y contrato "Contrato base" con un PDF. Empresa B: administrador creado para la prueba; todos los datos son ficticios.		
TIPO DE PRUEBA		
Seguridad – autorización (caja negra por API)		

Tabla 15**. Caso de prueba PT-PERF-001: Tiempo de respuesta de operaciones CRUD**

ID	NOMBRE	REQUERIMIENTO
PT-PERF-001	Tiempo de respuesta de operaciones CRUD	NFR-PERF-1 (apoyo: NFR-USAB-2)
DESCRIPCIÓN		

Medir la latencia de las operaciones CRUD simples bajo carga normal y compararla con el umbral del ERS (< 300 ms).
PRECONDICIONES
Stack levantado; base de datos con datos semilla más 1.000 clientes generados; k6 instalado; un token por usuario virtual.
PASOS
1. Poblar la base de datos de prueba y obtener un token por usuario virtual. 2. Ejecutar k6 con umbrales http_req_duration p(95) < 300 y http_req_failed < 1 % (script 03-Anexos/Herramientas/k6/crud_latencia.js). 3. Registrar promedio, p(95), p(99) y tasa de error por endpoint. 4. Repetir POST /autenticacion/login 30 veces y medir la latencia.
RESULTADO ESPERADO
p(95) < 300 ms en cada endpoint CRUD simple. Tasa de errores < 1 %. El login también cumple el umbral, por ser una operación simple del ERS.
CRITERIO DE ACEPTACIÓN
☐ p(95) < 300 ms para todos los endpoints CRUD simples. ☐ Errores 5xx < 1 %. ☐ El login cumple el mismo umbral.
DATOS DE PRUEBA
Carga normal: 20 usuarios virtuales durante 2 minutos, con tiempo de pensar de 1 s. Endpoints: GET /clientes, GET /clientes/{id}, POST /clientes, PUT /clientes/{id}, DELETE /clientes/{id}, GET /contratos y POST /autenticacion/login. El entorno es local: las cifras se reportan con las características del equipo y no se extrapolan a producción.
TIPO DE PRUEBA
Rendimiento – carga

Tabla 16**. Caso de prueba PT-USAB-001: Accesibilidad para adultos mayores (WCAG 2.1 AA)**

ID	NOMBRE	REQUERIMIENTO
PT-USAB-001	Accesibilidad para adultos mayores (WCAG 2.1 AA)	NFR-USAB-1; criterio ERS §3.1.1
DESCRIPCIÓN		
Evaluar si el login, el registro y las pantallas principales son legibles y operables por adultos mayores, con criterios WCAG 2.1 nivel AA.		
PRECONDICIONES		
Frontend disponible en http://localhost:3350; Lighthouse y axe DevTools instalados; usuario de prueba creado; participantes mayores de 60 años si es posible.		
PASOS		
1. Ejecutar Lighthouse (categoría Accesibilidad) y axe en cada URL. 2. Navegar solo con teclado (Tab, Shift+Tab, Enter, Esc) verificando foco visible y ausencia de trampas. 3. Medir contraste y tamaño de fuente base; ampliar el zoom al 200 %. 4. Pedir a los participantes iniciar sesión, crear un cliente y ubicar su contrato; registrar tiempo, errores y ayudas; aplicar el cuestionario SUS.		
RESULTADO ESPERADO		
Puntaje de accesibilidad en Lighthouse ≥ 90. 0 incidencias críticas o serias en axe. Contraste ≥ 4,5:1 y tarea completada sin bloqueos mayores.		
CRITERIO DE ACEPTACIÓN		
☐ Lighthouse Accesibilidad ≥ 90 en las 5 URLs. ☐ 0 incidencias critical/serious en axe.		

☐ Contraste de texto ≥ 4,5:1 y fuente base ≥ 12 px (mínimo del ERS). ☐ Objetivos táctiles ≥ 44×44 px y campos con label o ARIA. ☐ SUS promedio ≥ 70 y sin bloqueos mayores.
DATOS DE PRUEBA
URLs: /login, /registro, /home, /clientes, /contratos. Participantes: hasta 5 adultos mayores; como puede no ser factible conseguirlos, la alternativa es 1 o 2 participantes más revisión heurística, y la limitación se documenta. Tareas: iniciar sesión; crear un cliente; ubicar el contrato de ese cliente.
TIPO DE PRUEBA
Usabilidad / accesibilidad

4.2 Análisis de cobertura, pertinencia y coherencia del plan

Cobertura. Se mide de dos formas: de **diseño** (requerimientos del alcance con al menos un caso ÷ requerimientos del alcance) y de **ejecución** (casos ejecutados ÷ casos priorizados). El ERS define 42 requerimientos; el alcance de este ciclo se acotó por riesgo a 16 de ellos (sección 1.2), de modo que la cobertura de diseño del alcance es del **100 %** (16 de 16). Frente al ERS completo equivale a 38 %; los 26 requerimientos restantes no se verificaron y no pueden darse por cumplidos.

Tabla 17**. Cobertura de diseño por categoría de requerimientos**

Categoría del ERS	En el ERS	En el alcance	Con ≥ 1 caso	Casos que la verifican
Funcionales (RF-1.1 a RF-6.1)	17	7	7 (100 %)	FUNC-001, FUNC-002, FUNC-008, FUNC-010, SEG-002
Seguridad (NFR-SEG-1 a 9)	9	3	3 (100 %)	SEG-001, SEG-002, SEG-008
Rendimiento (NFR-PERF-1 a 3)	3	1	1 (100 %)	PERF-001
Usabilidad (NFR-USAB-1 a 4)	4	1	1 (100 %)	USAB-001
Disponibilidad (NFR-DIS-1 y 2)	2	0	—	Fuera del alcance
Compatibilidad (NFR-COMPAT-1 y 2)	2	0	—	Fuera del alcance
Reglas de negocio (RB-1 a 5)	5	4	4 (100 %)	FUNC-001, SEG-002, SEG-009
Total ERS	**42**	**16**	**16 (100 %)**	**10 casos**

Los diez casos verifican con evidencia ejecutada las cuatro reglas de negocio de mayor riesgo (RB-2 a RB-5), la autenticación y la sesión JWT, el flujo de contratos con documento, la gestión de clientes, la auditoría, el hash de contraseñas, el control de acceso por rol, el rendimiento CRUD y la accesibilidad. Los requerimientos de menor probabilidad o impacto (compatibilidad, disponibilidad, ayuda contextual, TLS y cifrado en reposo, entre otros) quedan fuera del alcance; en los de seguridad se apoyan en el análisis estático (sección 5.4).

Cobertura frente a estándares.

Tabla 18. Cobertura frente a ISO/IEC 25010, OWASP Top 10 y WCAG

Estándar	Cubierto por	Observación
ISO/IEC 25010: idoneidad funcional, eficiencia, usabilidad y seguridad	PT-FUNC-001, 002, 008, 010; PT-PERF-001; PT-USAB-001; PT-SEG-001, 002, 008, 009	Cobertura parcial: una muestra de los requerimientos de mayor riesgo.
ISO/IEC 25010: compatibilidad, fiabilidad, mantenibilidad y portabilidad	Análisis estático (mantenibilidad)	Sin caso de prueba: fuera del alcance.
OWASP A01 (control de acceso), A02 (fallas criptográficas), A07 (autenticación) y A09 (registro)	PT-SEG-002, 009; PT-SEG-001; PT-FUNC-002, PT-SEG-008; PT-FUNC-010	Cobertura directa.
OWASP A03, A05 y A06	SonarQube, ZAP baseline y Trivy	Solo por herramienta, sin caso dirigido.
OWASP A04, A08 y A10	PT-FUNC-001 (A04, parcial)	A08 y A10 sin cobertura.
WCAG 2.1 AA	PT-USAB-001	Medición automatizada (Lighthouse y axe); no incluye evaluación con usuarios.

En el marco legal, la Ley 19.628 (art. 11) se verifica con PT-SEG-001, 002, 008 y 009; la Ley 20.422, con PT-USAB-001; la Ley 21.719 se usa como referencia prospectiva; y la Ley 21.459 es una restricción transversal. El criterio de salida "cobertura de código ≥ 80 %" no es aplicable: SonarQube mide 0,0 % porque el repositorio no tiene pruebas automatizadas.

Pertinencia. Los casos se asignan por riesgo (probabilidad × impacto), con la probabilidad respaldada por la revisión estática (hallazgos H-xx de la sección 5.4).

Tabla 19. Pertinencia: riesgos, evidencia y pruebas asignadas

Riesgo	Prob.	Impacto	Evidencia que sustenta la probabilidad	Pruebas asignadas	Prioridad
Fuga de credenciales	Alta	Crítico	Contraseñas sin hash (H-01); sin política de contraseñas (H-15); secreto JWT por defecto (H-03)	PT-SEG-001, 008; PT-FUNC-002	P1
Acceso a datos de otra empresa o escalada de rol	Alta	Crítico	Sin control de rol (H-02); endpoints sin verificación de pertenencia (H-12, H-17, H-19)	PT-SEG-002, 009	P1
Documentos contractuales inseguros	Media	Alto	Carga de archivos sin filtro ni límite (H-08)	PT-FUNC-001	P1
Operaciones lentas	Alta	Medio	Latencia de 4 s en login (H-05)	PT-PERF-001	P2
Pérdida de trazabilidad	Media	Alto	Eliminación física (H-06); auditoría expuesta (H-19)	PT-FUNC-008, 010	P2
Exclusión de adultos mayores	Media	Medio	Requisito explícito NFR-USAB-1	PT-USAB-001	P2
Datos en tránsito o reposo sin protección; fallas de disponibilidad o compatibilidad	Media	Alto	Sin TLS (H-09); sin cifrado en reposo (H-13)	Sin caso; análisis estático	Fuera del alcance

Coherencia y brechas. Todo caso apunta a requerimientos existentes del ERS, los resultados esperados se derivan de su texto y los casos usan las rutas reales del backend; las herramientas se acotaron a las ejecutables en el entorno local. El criterio de salida "sin defectos críticos abiertos" no se cumple por los hallazgos de autorización, lo que es un resultado válido y no una incoherencia.

Brechas declaradas (fuera del alcance): compatibilidad, disponibilidad, TLS, cifrado en reposo, enlace compartido y la mayor parte de usabilidad; no se reunieron adultos mayores, por lo que la usabilidad se midió solo con herramientas automáticas; las pruebas de carga son locales y no extrapolables; y el sistema no tiene pruebas unitarias.

Conclusión. El alcance es pertinente al riesgo y coherente: los 16 requerimientos del alcance tienen caso (100 %) y los diez casos se ejecutaron (100 % de cobertura de ejecución). Los 26 requerimientos restantes del ERS quedan como riesgo residual en la sección 5.

5. Ejecución de pruebas

Las pruebas se ejecutaron el 29 de octubre de 2026 sobre el stack Docker Compose de Atlas (postgres:15-alpine, backend Node 18 y frontend nginx) en un equipo Linux Mint 22.3, con Chrome 156, k6 2.3.0, OWASP ZAP (imagen stable), SonarQube 26.10 y Lighthouse/axe. Se usaron datos ficticios y solo el entorno local. Solo se informa lo ejecutado; cada resultado tiene su archivo de evidencia en 06-Evidencias/ejecucion/.

5.1 Resumen de ejecución

Tabla 20**. Resumen de ejecución**

Métrica	Valor
Casos de prueba priorizados	10
Casos ejecutados	10 (100 % de cobertura de ejecución)
Aprobados	1
Fallidos	9
Bloqueados	0
Criterios de aceptación verificados	23 cumplidos de 47 evaluados
Análisis estático	SonarQube: 4 vulnerabilidades (1 Blocker), 25 bugs, 9 code smells · Trivy: 10 vulnerabilidades altas en dependencias y 3 críticas y 50 altas en la imagen del backend · Gitleaks: 0 secretos · Semgrep: 2 hallazgos · ZAP baseline: 0 alertas altas y 5 medias
Incidentes identificados	12: 4 críticos · 4 graves · 3 moderados · 1 leve

5.2 Detalle de ejecución de casos

Tabla 21**. Detalle de ejecución por caso (29 de octubre de 2026, Docker local)**

CASO	DESCRIPCIÓN DEL RESULTADO	RESULTADO	EVIDENCIA	TIPO
PT-FUNC-001	Contrato y descarga correctos (hash idéntico); se aceptan un .exe y un archivo de 30 MB; el documento se guarda en la BD; cliente inexistente → 500 con err.message.	Fallido	PT-FUNC-001_01_flujo_contrato.txt	Funcional

CASO	DESCRIPCIÓN DEL RESULTADO	RESULTADO	EVIDENCIA	TIPO
PT-FUNC-002	Login válido → 200 con JWT (exp 2 h); credenciales inválidas → 401. Latencia de 4 s.	Aprobado	PT-FUNC-002_01_login.txt	Funcional
PT-FUNC-008	Edición y filtro correctos; sin paginación (devuelve todos los clientes); eliminación física.	Fallido	PT-FUNC-008_01_clientes_crud.txt	Funcional
PT-FUNC-010	Crear, editar y eliminar se auditan; las descargas no; GET /auditoria sin token entrega todos los registros.	Fallido	PT-FUNC-010_01_auditoria.txt	Funcional
PT-SEG-001	Contraseñas en texto plano en la BD; sin bcrypt; "abc" y contraseñas sin símbolo aceptadas.	Fallido	PT-SEG-001_01_hash_politica.txt	Seguridad
PT-SEG-002	El token no incluye rol; el editor ejecutó 6 de 7 escrituras, incluida la creación de un usuario administrador.	Fallido	PT-SEG-002_01_rbac.txt	Seguridad
PT-SEG-008	Un token firmado con el secreto por defecto es aceptado; firma alterada, alg=none y expirado se rechazan.	Fallido	PT-SEG-008_01_jwt.txt	Seguridad
PT-SEG-009	Contratos y archivos de otra empresa accesibles (también sin token) y creación de contratos sin autenticación; los clientes sí están aislados.	Fallido	PT-SEG-009_01_aislamiento.txt	Seguridad
PT-PERF-001	POST, PUT y DELETE p95 entre 18 y 31 ms; GET /clientes y login p95 ≈ 4,0 s (umbral 300 ms).	Fallido	PT-PERF-001_01_k6.txt	Rendimiento
PT-USAB-001	Lighthouse 89 a 96; 49 nodos críticos o serios en axe (botones sin nombre, contraste); 96 de 119 objetivos < 44 px.	Fallido	PT-USAB-001_01_axe_lighthouse.txt	Usabilidad

5.3 Criticidad de incidentes

Tabla 22. Escala de criticidad de incidentes

CASO	DESCRIPCIÓN	IMPACTO	EVIDENCIA
CRÍTICO	Compromete confidencialidad, integridad o autenticación de datos personales, o impide una función esencial; explotable con privilegios mínimos. Ej.: contraseñas sin hash, escritura sin control de rol.	Muy alto: el sistema no es seguro de usar	Remediación inmediata; bloquea la liberación
GRAVE	Incumple un requerimiento esencial del ERS o expone un vector de ataque relevante, pero el sistema funciona parcialmente. Ej.: sin cierre de sesión, auditoría pública.	Alto: afecta áreas principales del usuario	Corregir con urgencia, antes de liberar
MODERADO	Debilita una defensa o degrada la calidad sin ruptura inmediata. Ej.: CORS abierto, sin política de contraseñas.	Medio: el usuario puede trabajar con limitaciones	Próxima iteración
LEVE	Desviación menor o de buenas prácticas que no afecta la funcionalidad. Ej.: divulgación de la versión del framework.	Bajo: no impacta la operación	Según disponibilidad

Tabla 23. Incidentes identificados y su criticidad

CASO	DESCRIPCIÓN	RESULTADO	IMPACTO	TIPO DE PRUEBA
PT-SEG-002 (INC-01)	Sin control de rol en el backend: el editor ejecuta 6 de 7 escrituras y crea un usuario administrador (escalada de privilegios). Viola NFR-SEG-4, RF-3.2, RB-4.	Fallido	**CRÍTICO**	Seguridad
PT-SEG-001 (INC-02)	Contraseñas en texto plano en la base de datos, sin bcrypt ni política de contraseñas. Viola NFR-SEG-2.	Fallido	**CRÍTICO**	Seguridad

CASO	DESCRIPCIÓN	RESULTADO	IMPACTO	TIPO DE PRUEBA
PT-SEG-009 (INC-03)	Contratos y archivos de otra empresa accesibles, incluso sin token, y contratos creables sin autenticación. Viola RB-2.	Fallido	CRÍTICO	Seguridad
PT-SEG-008 (INC-04)	El secreto JWT por defecto del docker-compose permite forjar tokens válidos y suplantar a cualquier usuario; la firma alterada, alg=none y el token expirado sí se rechazan. Viola NFR-SEG-9.	Fallido	CRÍTICO	Seguridad
PT-FUNC-010 (INC-05)	GET /auditoria sin autenticación entrega los registros de todas las empresas; las descargas de documentos no se auditan. Viola RF-6.1.	Fallido	GRAVE	Funcional / seguridad
PT-FUNC-001 (INC-06)	Se aceptan archivos .exe y de 30 MB, y el documento se guarda en la BD. Viola RF-5.2 y RF-5.3.	Fallido	GRAVE	Funcional
PT-PERF-001 (INC-07)	GET /clientes y el login tienen p95 de 4,0 s frente al umbral de 300 ms (retardo artificial en el código). Viola NFR-PERF-1.	Fallido	GRAVE	Rendimiento
SAST (INC-08)	Credencial de base de datos por defecto en db.js:6 (SonarQube Blocker) y en el docker-compose. Viola NFR-SEG-8.	Fallido	GRAVE	Análisis estático
PT-FUNC-008 (INC-09)	Sin paginación y eliminación física de clientes. Viola RF-4.2.	Fallido	MODERADO	Funcional
PT-USAB-001 (INC-10)	Accesibilidad insuficiente: Lighthouse 89 en /clientes y /contratos, botones sin nombre y contraste bajo. Viola NFR-USAB-1.	Fallido	MODERADO	Usabilidad
SAST (INC-11)	25 bugs de confiabilidad (promesas sin manejo de errores en el frontend) y 10 vulnerabilidades altas en dependencias (p. ej. multer 1.x).	Fallido	MODERADO	Análisis estático
SAST (INC-12)	El framework expone su versión (X-Powered-By: Express).	Fallido	LEVE	Análisis estático

5.4 Análisis estático del código

Se ejecutaron SonarQube Community 26.10 y Semgrep (SAST), Gitleaks (secretos) y Trivy (dependencias, configuración e imagen) en Docker, más una revisión manual del código. SonarQube analizó una copia del código con las dependencias instaladas, sin modificar el original (Anexo B). Un resultado de cero hotspots no significa ausencia de vulnerabilidades: la edición Community no hace análisis de flujo, por lo que los defectos de autorización se detectaron con los casos dinámicos.

Tabla 24. Resultados del análisis estático

Herramienta	Resultado
SonarQube (6.955 líneas)	4 vulnerabilidades (1 Blocker: credencial en db.js:6), 25 bugs, 9 code smells, 16,4 % de duplicación, 0 % de cobertura; Quality Gate OK
Trivy: dependencias y Dockerfiles	10 vulnerabilidades altas en BACKEND/package-lock.json (multer 1.4.5) y 2 configuraciones de riesgo alto en los Dockerfiles
Trivy: imagen del backend (node:18-alpine)	3 vulnerabilidades críticas y 50 altas (imagen base sin soporte)
Gitleaks	0 secretos detectados (la credencial de db.js la identifica SonarQube, no Gitleaks)
Semgrep (115 reglas: javascript y owasp-top-ten)	2 hallazgos: ambos Dockerfiles ejecutan el contenedor como root (regla missing-user)

La revisión manual produjo 19 hallazgos con archivo y línea (4 críticos, 9 graves y 6 moderados). Los de los casos priorizados se confirman en la sección 5.2; los demás cuentan con evidencia complementaria en 06-Evidencias/ejecucion/. Además, OWASP ZAP baseline (frontend y API) reportó 0 alertas altas y 5 medias (sin Content Security Policy, sin cabecera anti-clickjacking, sin Subresource Integrity y configuración CORS abierta).

Tabla 25. Hallazgos de la revisión estática manual contrastados con la ejecución

ID	Hallazgo	Requerimiento	Criticidad	Estado
H-01	Contraseñas sin hash (auth.js:26; datos semilla en texto plano)	NFR-SEG-2	**CRÍTICO**	Confirmado: PT-SEG-001
H-02	Sin control de rol en el backend (token sin rol)	NFR-SEG-4, RB-4	**CRÍTICO**	Confirmado: PT-SEG-002
H-12	POST /contratos sin autenticación ni verificación de empresa (IDOR)	RB-2, RB-3	**CRÍTICO**	Confirmado: PT-SEG-009
H-17	Descarga de documentos sin autenticación (GET /contratos/:id/file)	RB-2, NFR-SEG-4	**CRÍTICO**	Confirmado: PT-SEG-009
H-03	Secreto JWT por defecto en el código y el docker-compose	NFR-SEG-9	**GRAVE**	Confirmado: PT-SEG-008
H-04	Sin cierre de sesión ni revocación de tokens	RF-1.2	**GRAVE**	Confirmado en prueba complementaria
H-05	Latencia artificial de 4 s en login y GET /contratos	NFR-PERF-1	**GRAVE**	Confirmado: PT-PERF-001
H-08	Carga de archivos sin filtro ni límite; documento guardado en la BD	RF-5.2, RF-5.3	**GRAVE**	Confirmado: PT-FUNC-001; SonarQube
H-09	Sin TLS: nginx en puerto 80 y API por http	NFR-SEG-1	**GRAVE**	Confirmado en prueba complementaria
H-11	Credenciales por defecto en código y docker-compose	NFR-SEG-8	**GRAVE**	Confirmado: SonarQube
H-13	Datos bancarios sin cifrar en reposo	NFR-SEG-3	**GRAVE**	Confirmado en prueba complementaria
H-18	RF-5.5 (enlace compartido) no implementado	RF-5.5	**GRAVE**	Confirmado en prueba complementaria
H-19	Auditoría expuesta sin autenticación y manipulable	RF-6.1, RB-2	**GRAVE**	Confirmado: PT-FUNC-010
H-06	Eliminación física en lugar de lógica	RF-4.2	**MODERADO**	Confirmado: PT-FUNC-008
H-07	Errores 500 devuelven err.message	NFR-SEG-6	**MODERADO**	Confirmado en prueba complementaria
H-10	CORS abierto, sin helmet ni límite de intentos de login	NFR-SEG-5	**MODERADO**	Confirmado: SonarQube
H-14	Imagen node:18 sin soporte, contenedor como root, multer 1.x	NFR-SEG-5	**MODERADO**	Confirmado: Trivy
H-15	Sin política de contraseñas en el backend	§2.4 ERS	**MODERADO**	Confirmado: PT-SEG-001
H-16	Token JWT guardado en localStorage	NFR-SEG-9	**MODERADO**	Confirmado: código y pruebas de interfaz

6. Análisis ético y normativo de los resultados

6.1 Resultados frente a la normativa

Tabla 26. Resultados frente a la normativa

Resultado	Requerimiento	Norma o principio comprometido	Lectura
INC-01 y INC-04: el editor escribe y crea administradores; un token forjado suplanta a cualquiera	NFR-SEG-4, 9; RB-4	Ley 19.628 art. 11; OWASP A01 y A07	Cualquier persona con el secreto del compose puede operar como administrador y alterar datos de clientes de las pymes.
INC-02: contraseñas en texto plano	NFR-SEG-2	Ley 19.628 art. 11; Ley 21.719 (seguridad)	Un acceso a la base de datos expone credenciales reutilizables de los usuarios.
INC-03 y INC-05: contratos, archivos y auditoría accesibles sin control	RB-2; RF-6.1	Ley 19.628 art. 11; OWASP A01 y A09	Los documentos contractuales de una empresa pueden ser leídos por otra o por un anónimo; sin trazabilidad de descargas.
INC-08: credenciales por defecto en el código y en el compose	NFR-SEG-8	Ley 19.628 art. 11; OWASP A05	Los secretos están publicados en el repositorio y permiten acceder a la base de datos.
INC-10: accesibilidad insuficiente (Lighthouse 89, botones sin nombre, contraste bajo)	NFR-USAB-1	Ley 20.422; WCAG 2.1 AA	Barreras para adultos mayores y usuarios de lectores de pantalla; sin evaluación con usuarios reales.
INC-07: p95 de 4,0 s frente a 300 ms	NFR-PERF-1	ISO/IEC 25010 – eficiencia	Más de 13 veces el umbral del ERS; defecto de calidad por un retardo artificial en el código.

6.2 Análisis ético

- **Responsabilidad profesional:** los defectos de seguridad afectan a los clientes finales de las pymes; se reportan con su criticidad real, sin minimizarlos.
- **Honestidad de los resultados:** se informan 9 casos fallidos y 1 aprobado tal como ocurrieron y se declaran las limitaciones (sin usuarios reales, pruebas de carga locales y alcance acotado a 10 casos).
- **Privacidad desde el diseño:** debe evaluarse si Atlas necesita guardar el número de cuenta completo y por cuánto tiempo conserva datos de clientes eliminados (hoy la eliminación es física).
- **Inclusión:** el requerimiento para adultos mayores es un compromiso de equidad, no solo un criterio de aceptación.
- **Uso responsable de las pruebas:** solo en el entorno entregado por la asignatura, con datos ficticios (Ley 21.459); los hallazgos se comunican al equipo docente sin detalle explotable.

6.3 Recomendaciones

Tabla 27**. Recomendaciones vinculadas a la evidencia**

#	Recomendación	Incidente	Norma / principio	Prioridad
R1	Hashear contraseñas con bcrypt (costo ≥ 10) o Argon2, migrar las existentes y exigir una política de contraseñas en el backend.	INC-02	Ley 19.628 art. 11	Inmediata
R2	Incluir el rol en el JWT y aplicar un middleware de autorización en el backend; no confiar en el rol que envía el cliente.	INC-01	OWASP A01	Inmediata
R3	Verificar token y pertenencia a la empresa en todos los endpoints (contratos, archivos, auditoría) con un middleware global, y auditar también las descargas.	INC-03, INC-05	RB-2; RF-6.1; OWASP A01	Inmediata
R4	Exigir JWT_SECRET y credenciales de BD por variable de entorno; eliminar los valores por defecto del código y de docker-compose.	INC-04, INC-08	OWASP A05	Inmediata
R5	Eliminar el retardo artificial de 4 s y volver a medir con k6 hasta cumplir p95 < 300 ms.	INC-07	ISO/IEC 25010	Alta
R6	Validar tipo y tamaño de archivo, guardar documentos fuera de la BD y actualizar la imagen base y multer.	INC-06, INC-11	RF-5.2, RF-5.3; OWASP A06	Alta
R7	Paginar el listado de clientes y reemplazar la eliminación física por una lógica.	INC-09	RF-4.2	Media
R8	Hacer la interfaz accesible: nombres en botones, contraste y objetivos táctiles ≥ 44 px.	INC-10	Ley 20.422; WCAG 2.1 AA	Media

6.4 Conclusión

Se ejecutaron los 10 casos priorizados: 1 aprobado y 9 fallidos, con 12 incidentes (4 críticos, 4 graves, 3 moderados y 1 leve). El sistema **no está en condiciones de liberarse**: la ausencia de control de rol, las contraseñas en texto plano, la falta de aislamiento entre empresas y el secreto JWT por defecto comprometen la confidencialidad e integridad de los datos personales de terceros, con incumplimiento del deber de cuidado de la Ley 19.628. Los requerimientos fuera del alcance (compatibilidad, disponibilidad y parte de usabilidad y seguridad) quedan como riesgo residual.

Anexo A. Matriz de trazabilidad requerimiento–caso

La matriz relaciona cada caso con los requerimientos del alcance (ERS v1.1): 17 filas (16 requerimientos y 1 criterio de aceptación de interfaz), todas con al menos un caso de prueba (cobertura de diseño del alcance: 100 %). Los 26 requerimientos restantes del ERS están fuera del alcance de este ciclo (sección 1.2).

Tabla 28. Matriz de trazabilidad requerimiento–caso

Requerimiento	Caso(s) de prueba	Tipo
RF-1.1	PT-FUNC-002	Funcional
RF-3.2	PT-SEG-002	Seguridad (autorización)
RF-4.2	PT-FUNC-008	Funcional
RF-5.1	PT-FUNC-001	Funcional (E2E)
RF-5.2	PT-FUNC-001	Funcional
RF-5.3	PT-FUNC-001	Funcional
RF-6.1	PT-FUNC-010	Funcional
NFR-SEG-2	PT-SEG-001	Seguridad (SAST + BD)
NFR-SEG-4	PT-SEG-002	Seguridad (autorización)
NFR-SEG-9	PT-SEG-008	Seguridad (sesión)
NFR-PERF-1	PT-PERF-001	Rendimiento (carga)
NFR-USAB-1	PT-USAB-001	Usabilidad / Accesibilidad
RB-2	PT-SEG-009	Seguridad (aislamiento)
RB-3	PT-FUNC-001	Funcional
RB-4	PT-SEG-002	Seguridad (autorización)
RB-5	PT-SEG-002	Seguridad / Funcional
§3.1.1	PT-USAB-001	Usabilidad

Anexo B. Evidencia del análisis estático con SonarQube

Tabla 29. Ficha del análisis con SonarQube

Ficha del análisis	Detalle
Herramienta	SonarQube Community 26.10.0.133078 en Docker (imagen sonarqube:community) y sonarsource/sonar-scanner-cli
Proyecto y fecha	atlas-ep3 · 29 de octubre de 2026
Alcance	BACKEND/src y FRONTEND/src de CodigoFuenteA, analizados con dependencias instaladas (npm install); el código original no se modificó
Métricas	6955 líneas de código · 4 vulnerabilidades · 25 bugs · 9 code smells · 0 security hotspots · 16,4 % de duplicación · cobertura 0,0 %
Archivos de evidencia	Carpeta 06-Evidencias/estatico/: sonarqube_metricas.json, sonarqube_vulnerabilidades.json, sonarqube_bugs.json, sonarqube_code_smells.json y capturas sonarqube_01 a 04

Tabla 30. Vulnerabilidades detectadas por SonarQube

Severidad	Regla	Ubicación	Mensaje de SonarQube	Esfuerzo	Hallazgo · req.
BLOCKER	secrets:S6698	BACKEND/src/db.js:6	Make sure this PostgreSQL password gets changed and removed from the code.	30min	H-11 · NFR-SEG-8
MAJOR	javascript:S5122	BACKEND/src/app.js:22	Make sure that enabling CORS is safe here.	4h	H-10 · NFR-SEG-5
MAJOR	javascript:S5693	BACKEND/src/routes/contracts.js:15	Make sure the content length limit is safe here.	5min	H-08 · RF-5.2
MINOR	javascript:S5689	BACKEND/src/app.js:20	This framework implicitly discloses version information by default. Make sure it is safe here.	5min	H-10 · NFR-SEG-5

Bugs (25): 24 por promesas sin await ni .catch en el frontend (regla S9383) y 1 por falta de familia de fuentes genérica; son defectos de confiabilidad, no de seguridad. **Code smells (9):** todos por usar parseInt en lugar de Number.parseInt (regla S7773), con impacto bajo. El panel muestra Reliability = 34 porque agrupa por cualidad afectada: suma los 25 bugs y los 9 code smells que también inciden en confiabilidad.

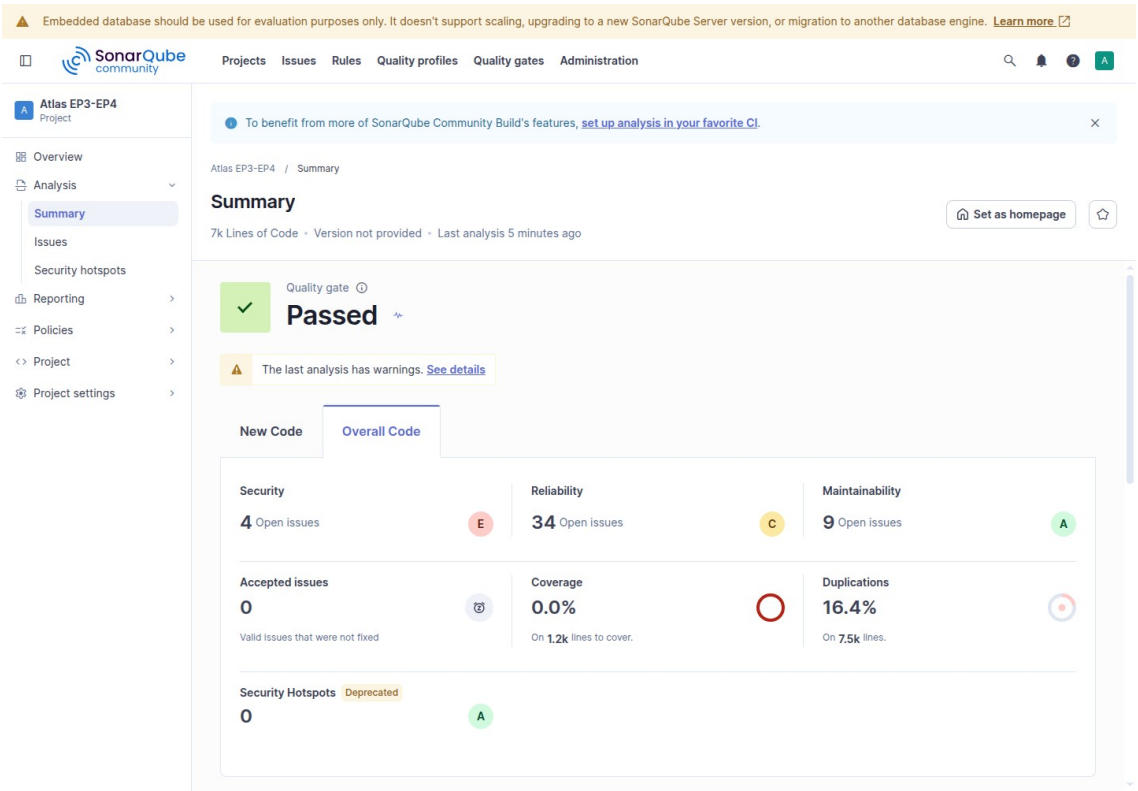


Figura B.1. Resumen del proyecto: Quality Gate "Passed", Security 4, Reliability 34, Maintainability 9, duplicación 16,4 %.

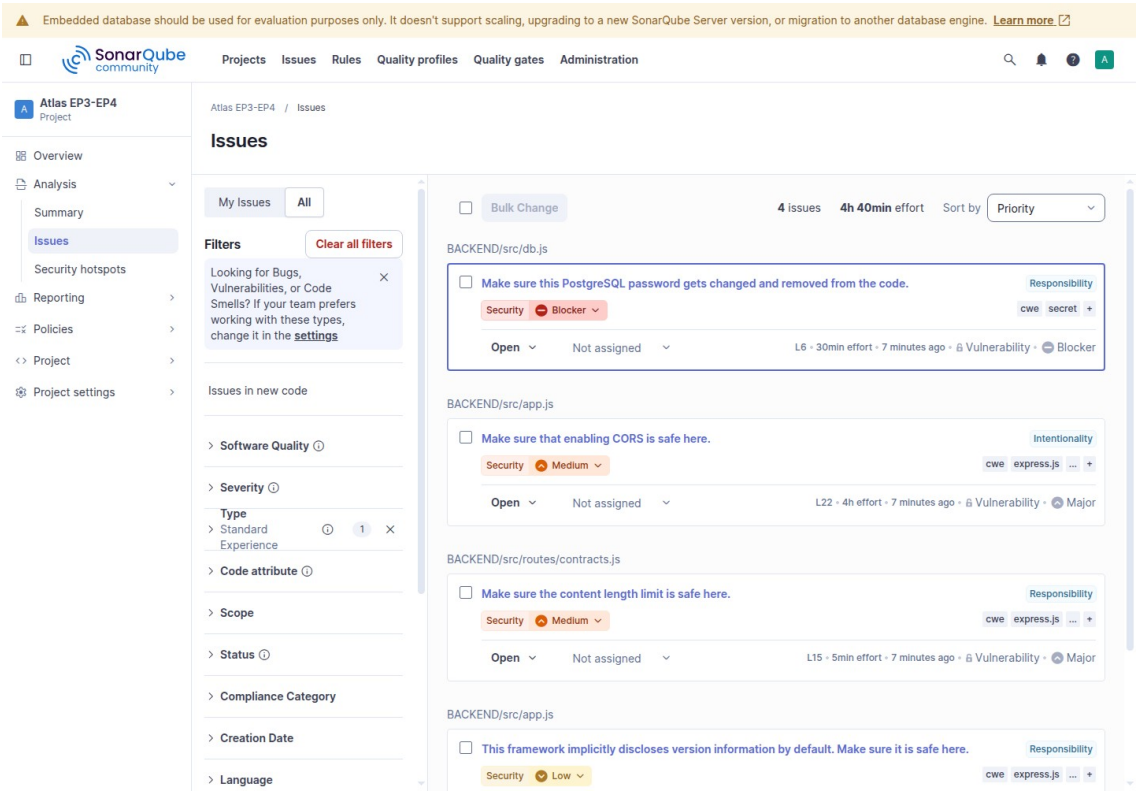


Figura B.2. Las 4 vulnerabilidades, con db.js:6 clasificada Blocker.

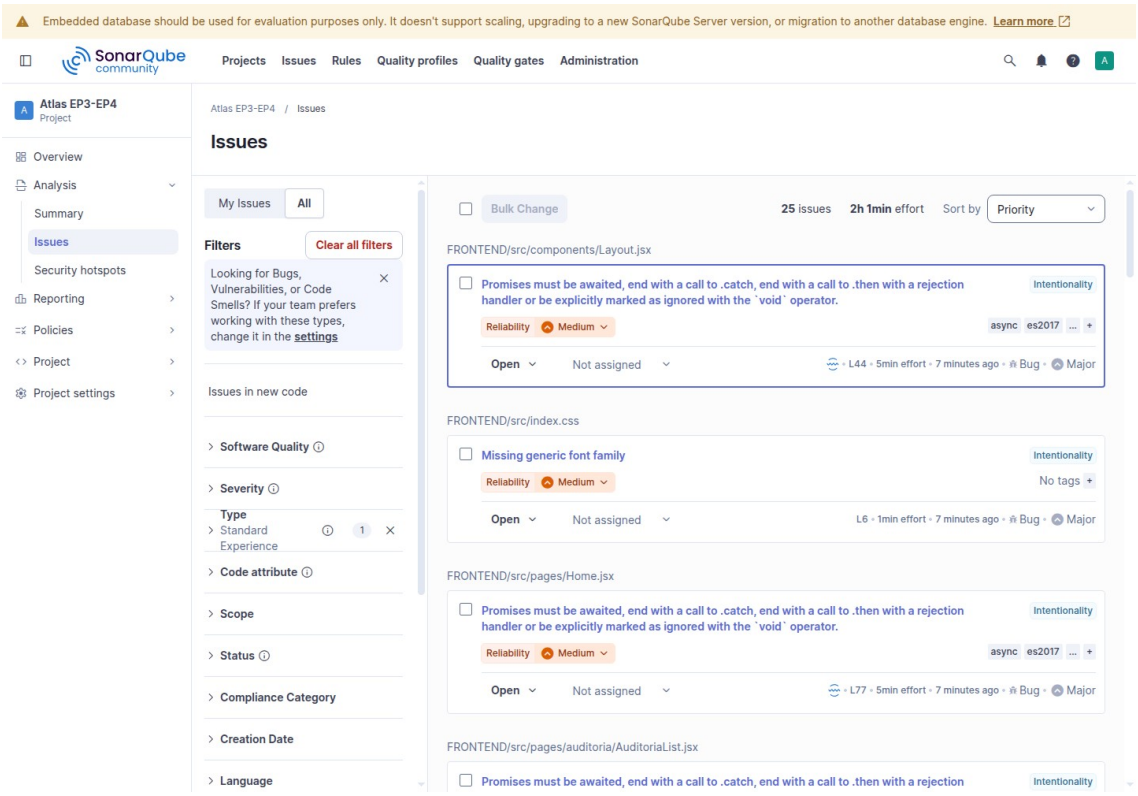


Figura B.3. Bugs (25): promesas sin manejar en componentes del frontend.